

VindobonaPay GmbH — NIS2 Applicability & Gap Analysis

Deliverable 04 | Comparative analysis for a DORA financial entity | Directive (EU) 2022/2555 — Articles 20, 21(2)(a)-(j), 23 | Version 2.0 | Fictional company for educational purposes

#	NIS2 requirement	NIS2 Article	Legal applicability	Applicability note (legal basis)	Corresponding DORA obligation	Implementation assessment	Supporting evidence (ISMS)	Gap description	Remediation action	Owner	Target
N-01	Management body approval, oversight and cybersecurity training	Art. 20	Disapplied — DORA lex specialis	Governance duties of the management body concerning ICT risk are closely connected to the risk-management measures covered by the Article 4 carve-out. DORA Art. 5 imposes an equivalent duty on the management body of a financial entity, so the directly applicable legal basis is DORA.	DORA Art. 5(2), 5(4); Art. 13(6)	Partially implemented	A.5.4 management responsibilities; management review meetings; InfoSec Policy approved by management (Clauses 5.1, 9.3).	Policies are approved and reviewed, but there is no formal cybersecurity training programme for the management body and no record of it.	Deliver a yearly ICT risk briefing to the management body and keep attendance records.	CISO	Q4 2026
N-02	Risk analysis and information system security policies	Art. 21(2)(a)	Disapplied — DORA lex specialis	Covered by the DORA ICT risk management framework.	DORA Art. 6, Art. 8	Implemented	ISMS risk assessment methodology (Clause 6.1); Risk Register with 16 risks (Deliverable 01); InfoSec Policy v1.0.	No gap: risk assessment, register and treatment decisions are documented and reviewed.	Maintain the yearly review cycle; align framework documentation with DORA Art. 6.	CISO	Ongoing
N-03	Incident handling	Art. 21(2)(b)	Disapplied — DORA lex specialis	Covered by DORA Art. 17 (incident management process) and Art. 18 (classification).	DORA Art. 17, Art. 18	Partially implemented	A.5.24 to A.5.28; Incident Response Plan v1.1 with triage criteria; incident response runbooks.	Incident handling works internally, but incidents are not classified against the regulatory criteria that determine reporting obligations.	Add a classification step aligned with DORA criteria to the Incident Response Plan.	CISO	Q1 2027
N-04	Business continuity, backup management and crisis management	Art. 21(2)(c)	Disapplied — DORA lex specialis	Covered by DORA Art. 11 (response and recovery) and Art. 12 (backup and restoration).	DORA Art. 11, Art. 12	Partially implemented	A.5.29, A.5.30, A.8.13, A.8.14; Azure Backup with restore tests; RTO/RPO defined; BCP in draft.	Backups are tested, but the Business Continuity Plan is still in draft and no ICT continuity test has been run yet.	Approve the BCP and run the first ICT continuity test.	COO	Q4 2026
N-05	Supply chain security	Art. 21(2)(d)	Disapplied — DORA lex specialis	Covered by DORA Chapter V, which is considerably more detailed (register of information, contractual provisions, concentration risk, exit strategies). Assessed as a DORA Chapter V gap; NIS2 Art. 21(2)(d) is retained as the comparative reference.	DORA Chapter V — Art. 28, 29, 30	Gap	A.5.19 to A.5.22; supplier list with risk rating (partial); security clauses in the main contracts.	No structured supplier assessment cycle, no register of ICT contractual arrangements and no exit strategies for critical services.	Build the ICT third-party risk procedure and the register of information (see Deliverable 05).	Compliance Officer	Q1 2027
N-06	Security in acquisition, development and maintenance, including vulnerability handling	Art. 21(2)(e)	Disapplied — DORA lex specialis	Covered by the DORA ICT risk framework and testing requirements.	DORA Art. 8, Art. 9; Art. 24, 25	Partially implemented	A.8.8, A.8.25 to A.8.29, A.8.32; SAST in the CI pipeline; yearly external penetration test; monthly vulnerability scans.	Secure development practices are in place but the SDLC procedure is not formalized, and patch SLAs by severity are not defined.	Formalize the secure SDLC procedure and define patch SLAs by severity.	Head of Engineering	Q4 2026
N-07	Policies and procedures to assess the effectiveness of risk-management measures	Art. 21(2)(f)	Disapplied — DORA lex specialis	Covered by DORA Art. 6(5) and 6(6) (framework review and internal audit) and Chapter IV (resilience testing).	DORA Art. 6(5), 6(6); Chapter IV	Gap	ISMS Clauses 9.1, 9.2 and 9.3; A.5.35 independent review; no internal audit performed yet.	The first internal ISMS audit has not been carried out, so control effectiveness is not yet independently assessed.	Schedule and run the first internal ISMS audit; plan the resilience testing programme.	Management	Q1 2027
N-08	Basic cyber hygiene practices and cybersecurity training	Art. 21(2)(g)	Disapplied — DORA lex specialis	Covered by DORA Art. 13(6) (awareness programmes and training).	DORA Art. 13(6)	Implemented	A.6.3 and Clauses 7.2, 7.3; yearly awareness training for all staff; phishing simulations; training records kept.	No gap for general staff. Management-level training is tracked separately under N-01.	Maintain the yearly cycle and extend simulations to new joiners.	CISO	Ongoing
N-09	Policies and procedures on the use of cryptography and encryption	Art. 21(2)(h)	Disapplied — DORA lex specialis	Covered by DORA Art. 9 (protection and prevention).	DORA Art. 9	Implemented	A.8.24; cryptography standard; TLS in transit; encryption at rest in Azure, full-disk encryption on laptops.	No gap: encryption is applied in transit, at rest and on endpoints, with documented key management.	Review the cryptography standard yearly against evolving guidance.	Head of Engineering	Ongoing
N-10	Human resources security, access control policies and asset management	Art. 21(2)(i)	Disapplied — DORA lex specialis	Covered by DORA Art. 8 (identification) and Art. 9 (protection).	DORA Art. 8, Art. 9	Partially implemented	A.6.1 to A.6.6; A.5.15 to A.5.18; A.8.2, A.8.3; asset inventory; Access Control Policy v1.0.	HR security and asset inventory are in place; access reviews are still ad-hoc rather than a quarterly cycle, and the segregation of duties matrix is in draft.	Introduce quarterly access reviews and finalize the segregation of duties matrix.	IT Manager	Q4 2026
N-11	Multi-factor authentication and secured communications	Art. 21(2)(j)	Disapplied — DORA lex specialis	Covered by DORA Art. 9. NIS2 names MFA explicitly; DORA requires strong authentication as part of protection measures.	DORA Art. 9	Partially implemented	A.8.5, A.8.2; MFA and Conditional Access enforced for all users in Entra ID; separate admin accounts.	MFA is enforced for all users, but privileged accounts are not yet protected by phishing-resistant methods and just-in-time elevation is not enforced (see R-02).	Roll out FIDO2 keys for privileged accounts and introduce Privileged Identity Management.	IT Manager	Q3 2026
N-12	Incident notification to the authorities (early warning 24h, notification 72h, final report 1 month)	Art. 23(3), 23(4)	Disapplied — DORA lex specialis	Covered by DORA Art. 19 for major ICT-related incidents. Reports go to the financial competent authority (FMA), not to the CSIRT under the NIS2 regime.	DORA Art. 19	Gap	A.5.5 authority contact list (FMA, CERT.at); A.5.31 legal and regulatory register.	Authority contacts exist, but there is no documented reporting workflow with deadlines, templates and responsibilities.	Define the regulatory incident reporting procedure with DORA timelines (see Deliverable 05).	Compliance Officer	Q1 2027

Legal applicability

Directly applicable	The NIS2 provision applies to VindobonaPay as written.
Disapplied — DORA lex specialis	Superseded by an equivalent DORA obligation under NIS2 Article 4.
Indirect / contractual relevance	Not a direct obligation, but may reach VindobonaPay through customer contracts.
Not applicable	Outside the defined organizational scope.

Implementation assessment (against the applicable obligation — DORA where the NIS2 provision is disapplied)

Implemented	Supported by controls assessed as fully implemented in the SoA.
Partially implemented	Supported by controls assessed as partially implemented.
Gap	No supporting control or process in place.
Not assessed	Outside the scope of this exercise.

Legal applicability and implementation maturity are assessed separately. The analysis never states that VindobonaPay has a 'NIS2 gap' on a provision that does not apply to it: it states that the NIS2 provision is disapplied, and that the corresponding DORA obligation shows a gap.

Legal basis for the carve-out: NIS2 Art. 4 (sector-specific Union legal acts) and DORA Art. 1(2), confirmed by DORA Recital 16 and NIS2 Recital 28, and by the European Commission guidelines on the application of Art. 4(1) and (2) of Directive (EU) 2022/2555.

Requirements marked as disapplied remain documented with their DORA equivalent: the corresponding DORA obligation may be more detailed, prescriptive or sector-specific, and the reasoning must be visible to an auditor.

The treatment of Art. 20 (management body) under the Article 4 carve-out is the point most open to debate. This analysis treats the governance duties as closely connected to the risk-management measures and therefore covered, with DORA Art. 5 as the directly applicable basis. In a real project this reading would be confirmed with legal counsel.

Austrian legal status assessed as of July 2026: Austria transposed NIS2 through the NISG 2026 (Art. 1 of BGBl. I No. 94/2025, published 23 December 2025), whose substantive provisions enter into force on 1 October 2026, with registration of in-scope entities required within three months. Whether a DORA financial entity carries residual administrative or registration duties under the NISG 2026 is a question of Austrian national law and is not resolved in this exercise.

Sources: EUR-Lex (Directive (EU) 2022/2555; Regulation (EU) 2022/2554). No regulatory text is reproduced: articles are referenced by number and described in my own words.

NIS2 Gap Analysis — Summary

Version 2.0 — all values calculated automatically (COUNTIF) from the Gap Analysis sheet.

Requirements assessed	12
-----------------------	----

BY LEGAL APPLICABILITY	
Directly applicable	0
Disapplied — DORA lex specialis	12
Indirect / contractual relevance	0
Not applicable	0

BY IMPLEMENTATION ASSESSMENT	
Implemented	3
Partially implemented	6
Gap	3
Not assessed	0

Headline finding: none of the substantive NIS2 requirements assessed applies directly to VindobonaPay. All are disapplied under the Article 4 carve-out and assessed instead against their DORA equivalent.

The three gaps — supply chain security (DORA Chapter V), effectiveness assessment (DORA Art. 6(5), 6(6)) and incident notification (DORA Art. 19) — are the same areas rated 'No direct support' in Deliverable 03. All three are addressed under DORA in Deliverable 05.

The carve-out does not remove every interaction with the NIS2 ecosystem: national administrative obligations under the NISG 2026 and contractual requirements imposed by NIS2-regulated customers are assessed separately.